

ChronosAudit: A Production-Oriented, Information-Admissible Framework for Pre-Incident Smart-Contract Exploit Detection

Anonymous manuscript

Empirical software engineering / blockchain security research article

Abstract

Pre-incident smart-contract exploit detection is easy to overstate retrospectively because the evaluator can observe artifacts that a defender did not possess before an incident: post-incident source verification, exploit transactions, upgraded proxy implementations, public root-cause labels, duplicated deployments, and related protocol or mechanism families. We present ChronosAudit, a real-world evidence and evaluation infrastructure that treats every detector input as a time-indexed admissibility claim. The system separates detector-visible evidence from evaluator-only outcomes; fixes an outcome-independent primary prediction landmark 24 h after deployment with preregistered 1 h, 7 d, and 30 d sensitivity landmarks; reconstructs canonical historical bytecode and proxy identity with block-hash-pinned multi-provider RPC reads; records first-defensible source availability; creates blinded dual-review packets and immutable third-adjudication records; constructs a deployment denominator and cutoff-safe matched controls; preserves right censoring; and certifies R0-R5 partitions over exact identity, bytecode clone, proxy implementation, protocol family, and exploit-mechanism family. In the executed public-evidence layer, all 417 historical exploit tasks are linked to content-hashed incident records, yielding 408 unique chain-address identities and nine repeated identity groups. Exact-identity leakage occurs in 100% of 1,000 independent-random, balanced shuffled K-fold, and chain-stratified K-fold simulations, while identity-group K-fold has zero crossings. The closed-form expectation for nine duplicate pairs under independent five-fold assignment is 7.2 crossing groups and a 99.9999488% probability of at least one crossing, demonstrating that the simulation is a validation check rather than the substantive novelty claim. The revised implementation passes 38 automated tests and adds cutoff-safe matching, blinded review, third-adjudicator ingestion, multiple trace backends, retry/backoff, statistical utilities, and deterministic split auditing. ChronosAudit deliberately releases no detector-effectiveness cohort until live dual-provider historical evidence, independently reviewed labels, a $\geq 20,000$ -contract deployment denominator, $\geq 4,170$ matched controls, longitudinal outcomes, and independent external regeneration pass frozen gates. The contribution is therefore a production-oriented measurement system for making future pre-incident detector-effectiveness claims falsifiable, auditable, and resistant to information leakage.

Keywords: smart-contract security; pre-incident detection; temporal leakage; benchmark contamination; historical blockchain state; source provenance; censoring; reproducibility

1. Introduction

Smart contracts increasingly mediate financial and governance workflows whose failures can produce immediate, irreversible losses. A detector used in practice must therefore answer a temporal question: could it have produced a useful warning before an exploit became known, using only information actually available at that time? Retrospective evaluation often answers a weaker question. Once an incident occurs, source code may be verified or republished, exploit transactions reveal state transitions, proxy implementations may be upgraded, public post-mortems localize the root cause, and benchmark curators may unintentionally place related contracts in both training and test data. Performance obtained under those conditions is not automatically evidence of pre-incident capability.

Existing work already establishes that realism and data hygiene materially change vulnerability-detection results. PrimeVul shows that aggressive deduplication and chronological splitting can collapse code-language-model performance relative to conventional vulnerability datasets [1]. DAppSCAN demonstrates the difficulty of evaluating smart-contract analyzers on large collections derived from real audit reports [2], and SmartBugs exposes substantial disagreement among automated analyzers [3]. DIVE explicitly reports repeated opcode skeletons and warns about train/test leakage in smart-contract data [4]. Recent agent benchmarks move closer to operational reality: EVMbench evaluates detection, exploitation and patching [9], ReEVMbench introduces post-model-release incidents to reduce model-training contamination [10], SCONE evaluates exploitation on historical state [11], and CyberChainBench

anchors hundreds of real incidents to historical execution environments [12]. These advances leave a complementary measurement problem unresolved: historical executability is not the same as historical information admissibility.

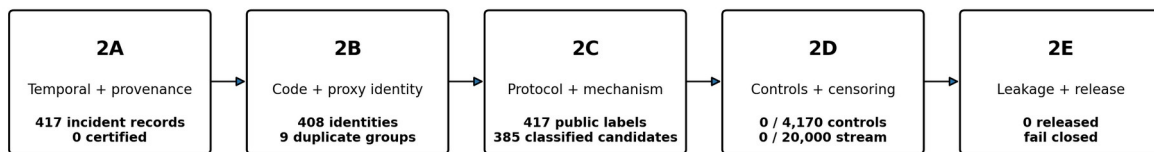
ChronosAudit treats benchmark construction as a chain of evidence claims. The atomic unit is a specific chain-address deployment observed at a frozen prediction cutoff. Every detector-visible artifact must have a defensible availability time, provenance record, integrity hash and lineage status. Evaluator-only information such as exploit transactions and post-incident labels is permitted for outcome adjudication but cannot leak into detector inputs. If a required field cannot be established, the case remains in the audit ledger but is excluded from detector-effectiveness claims. This fail-closed design prevents a benchmark from silently becoming easier as more information appears after the incident.

This article reports the complete design and executable implementation of the Stage-2 evidence/cohort layer required by the broader ChronosAudit program. It does not manufacture detector performance in the absence of a scientifically qualified cohort. Instead, it closes the implementation defects identified in prior internal review, freezes the statistical and temporal policies that later stages depend on, and reports exactly which claims are already supported by executed public evidence and which still require live independent evidence. This distinction is essential for top-journal empirical work: a reproducible negative release decision is preferable to a populated benchmark whose information boundary cannot be defended.

The paper makes six contributions:

- A contract-at-cutoff information-admissibility model with an outcome-independent 24-hour primary landmark and preregistered 1-hour, 7-day and 30-day sensitivity landmarks.
- A real-world historical reconstruction implementation using canonical block-hash pinning, independent-provider consensus, common proxy resolution, multiple trace backends, source-history evidence, response hashing, and fail-closed provider-family independence checks.
- A blinded two-reviewer plus third-adjudicator workflow with raw agreement, Cohen kappa, Gwet AC1, bootstrap confidence intervals, immutable final-decision hashes, and explicit separation of machine candidates from first-pass human judgments.
- A cutoff-safe denominator/control design in which controls must already exist at the positive case cutoff; no future activity or outcome is allowed into matching. The design preserves unresolved/right-censored outcomes and defines IPCW and partial-identification analyses.
- A contamination audit that compares independent random, balanced shuffled, chain-stratified and identity-group K-fold splitting, and generalizes the release protocol to R0-R5 family separation.
- An executable, versioned artifact that currently links all 417 seed incidents to hashed public chronology while refusing to release detector-effectiveness cases until historical, reviewer, denominator, control, longitudinal and external-reproduction gates are actually satisfied.

ChronosAudit Stage 2A-2E evidence qualification pipeline



Missing mandatory evidence at any stage -> reason-coded exclusion -> no detector-effectiveness release

EXECUTED PUBLIC LAYER COMPLETE; EXTERNAL EVIDENCE GATES REMAIN BLOCKED

Figure 1. ChronosAudit Stage-2 evidence/cohort qualification pipeline.

Fail-closed evidence claims; no unexecuted live gate is reported as complete

2. Research objective, estimands and completion gate

The target claim is deliberately narrower than “zero-day prediction.” ChronosAudit asks whether a detector, supplied only with artifacts admissible at a frozen pre-incident cutoff, can discriminate later exploited contracts from contemporaneous controls and retain capability as increasingly strict contamination constraints are imposed. The primary scientific estimand in later detector stages is the change in precision-recall performance and analyst workload between conventional and contamination-controlled partitions, with uncertainty clustered at the strongest available dependency family. Stage 2 is complete only when the cohort itself is scientifically defensible; detector scores are not computed from cases that fail mandatory evidence gates.

RQ	Question	Stage-2 completion criterion
RQ1	Can deployment, code, source and identity evidence be reconstructed as they existed at a frozen pre-incident cutoff?	Two independent provider families agree on canonical historical state; source availability is positively evidenced or marked unknown.
RQ2	Can protocol and exploit-mechanism families be labeled without machine anchoring or single-reviewer authority?	Two blinded reviewers complete all cases; disagreements receive a third adjudicator; agreement statistics and confidence intervals are reported.
RQ3	Can positives be embedded in a real deployment risk set without future-information leakage?	$\geq 20,000$ real deployments are collected; ≥ 10 cutoff-safe matched controls per positive are frozen; unresolved outcomes remain censored.
RQ4	Can train/test dependency be eliminated successively from exact identity through held-out mechanism family?	R0-R5 contamination graph is complete; required leakage is zero; ≥ 120 independent R5 blocks remain.
RQ5	Can another group regenerate the released cohort and partitions from frozen public inputs and provider observations?	Independent re-execution reproduces cohort membership and partition hashes within preregistered tolerances.

3. Related work and scholarly positioning

3.1 Static, symbolic and learning-based smart-contract analysis

Smart-contract security research includes static analysis, symbolic execution, fuzzing and learned representations. Slither provides a widely used static-analysis framework and intermediate representation for Solidity [5]. SmartBugs integrates multiple analyzers and, in a large empirical study, showed both limited shared detection and substantial false-positive concerns [3]. GPTScan combines LLM-guided candidate reasoning with program-analysis confirmation for logic vulnerabilities [6]. MANDO learns heterogeneous control-flow and call-graph representations at contract and line level [7], while MANDO-LLM combines heterogeneous graph transformers with LLM-derived features [8]. These systems address how to detect vulnerabilities; ChronosAudit addresses whether an evaluation gives those systems only information a defender could legitimately have possessed before the incident.

3.2 Dataset quality, deduplication and temporal contamination

Dataset contamination is not a smart-contract-specific concern. PrimeVul shows that label quality, duplication and unrealistic splits can substantially inflate vulnerability-detection estimates, with large performance degradation after stronger deduplication and chronological evaluation [1]. DAppSCAN builds source- and bytecode-level smart-contract datasets from 1,199 audit reports and 9,154 weaknesses, emphasizing realistic project data [2]. DIVE contributes a multi-label smart-contract dataset and explicitly identifies repeated opcode skeletons as a leakage risk [4]. ChronosAudit extends this line of work from duplicate functions or opcode structure to a broader dependency graph: chain-address identity, normalized bytecode, proxy implementation lineage, protocol/entity family and exploit-mechanism family.

3.3 Historical exploit and agent benchmarks

EVMbench evaluates AI agents on detection, exploitation and patching across curated vulnerabilities [9]. ReEVMbench demonstrates that model/scaffold rankings can change when evaluation uses 22 incidents that postdate model releases, highlighting training-data contamination and scaffold choice as empirical threats [10]. SCONE evaluates smart-contract exploitation in historical simulation and includes post-knowledge-cutoff tasks [11]. CyberChainBench expands real-world agent evaluation to 541 incidents across nine EVM chains with historical

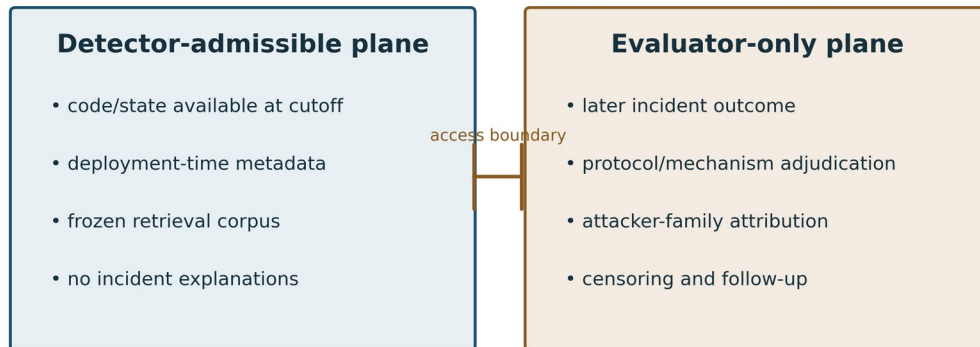
blockchain state and structured ground truth [12]. Chaliasos et al. evaluate five security tools against 127 high-impact real attacks and find that only a small minority were preventable by those tools [29]. Bastet contributes 849 fully expert-annotated DeFi findings produced by a two-annotator consensus workflow, providing a useful external reference for human-label reliability [30]. These benchmarks improve task realism and label quality; ChronosAudit targets a distinct validity dimension. A contract may be executable at an old block while its source, proxy implementation annotation, protocol relationship or exploit-family label became known only later. Historical state is therefore necessary but not sufficient for a pre-incident claim.

3.4 Gap summary

Capability	Representative prior work	ChronosAudit addition
Real-world smart-contract weaknesses	DAppSCAN, SmartBugs, DIVE [2-4]	Time-index every detector artifact and preserve unknown availability rather than substituting current artifacts.
Graph/LLM detection	MANDO, MANDO-LLM, GPTScan [6-8]	Detector-agnostic admissibility and family-controlled evaluation.
Historical execution	SCONE, CyberChainBench [11-12]	Block-hash-pinned multi-provider identity plus source-at-cutoff and proxy-lineage admissibility.
Agent capability	EVMbench, ReEVMbench [9-10]	Explicit model-independent contamination ladder and release gate.
General vulnerability leakage	PrimeVul [1]	Extend deduplication from code/time to deployment, proxy, protocol and mechanism families.
Dataset documentation	Datasheets [24]	Hash-linked evidence registry, reason-coded exclusions, external-evidence gate ledger and deterministic regeneration.

4. Threat model and information-admissibility model

The adversary in the validity analysis is not only an exploit attacker; it is also accidental benchmark leakage. Leakage can occur when a detector receives information that was unavailable at the cutoff, when related contracts straddle train/test partitions, or when an apparently negative control is labeled safe despite insufficient follow-up. ChronosAudit therefore distinguishes two information planes. The detector plane contains only artifacts with positive pre-cutoff admissibility evidence. The evaluator plane may contain later incident reports, exploit transactions and adjudication notes, but those fields are physically and logically excluded from detector adapters.



Evaluator-only information may audit contamination but must never enter model inputs, prompts, tools, or retrieval.

Figure 2. Detector-visible and evaluator-only information planes.

$$t_{\text{deploy}} < t_{\text{cut}} < t_{\text{incident}} \quad (1)$$

The primary prediction cutoff is frozen from deployment time alone: the first canonical observation at or after deployment + 24 hours. Incident time is used only after the cutoff is fixed, to determine whether the case has at least one hour of lead time. Sensitivity analyses repeat the cohort construction at deployment + 1 hour, +7 days and +30

days. Incidents that occur before a landmark are not moved to a convenient pre-incident time; they are ineligible for that landmark and may enter an earlier preregistered sensitivity stratum. This rule prevents retrospective knowledge of the exploit date from moving the cutoff.

Landmark	Definition	Purpose
Primary	deployment + 24 h; require ≥ 1 h lead before incident	Outcome-independent main analysis.
Early	deployment + 1 h	Captures rapidly exploited deployments.
Medium	deployment + 7 d	Tests stability after short operational exposure.
Long	deployment + 30 d	Tests mature-contract evidence and survivor effects.

5. Real-world positive cohort and incident evidence

The frozen seed contains 417 SCONE tasks sourced from DeFiHackLabs: 226 on BNB Smart Chain, 181 on Ethereum mainnet, 9 on Base and 1 on Arbitrum. The enrichment pipeline maps every task to a content-hashed public incident record, preserving the source snapshot hash, incident-record hash, public incident name/date, raw public mechanism description and any transaction-hash hints. Coverage of the public chronology layer is 417/417. This does not mean 417/417 incidents are independently adjudicated ground truth; it means every seed row has a reproducible public incident linkage that can be independently checked.

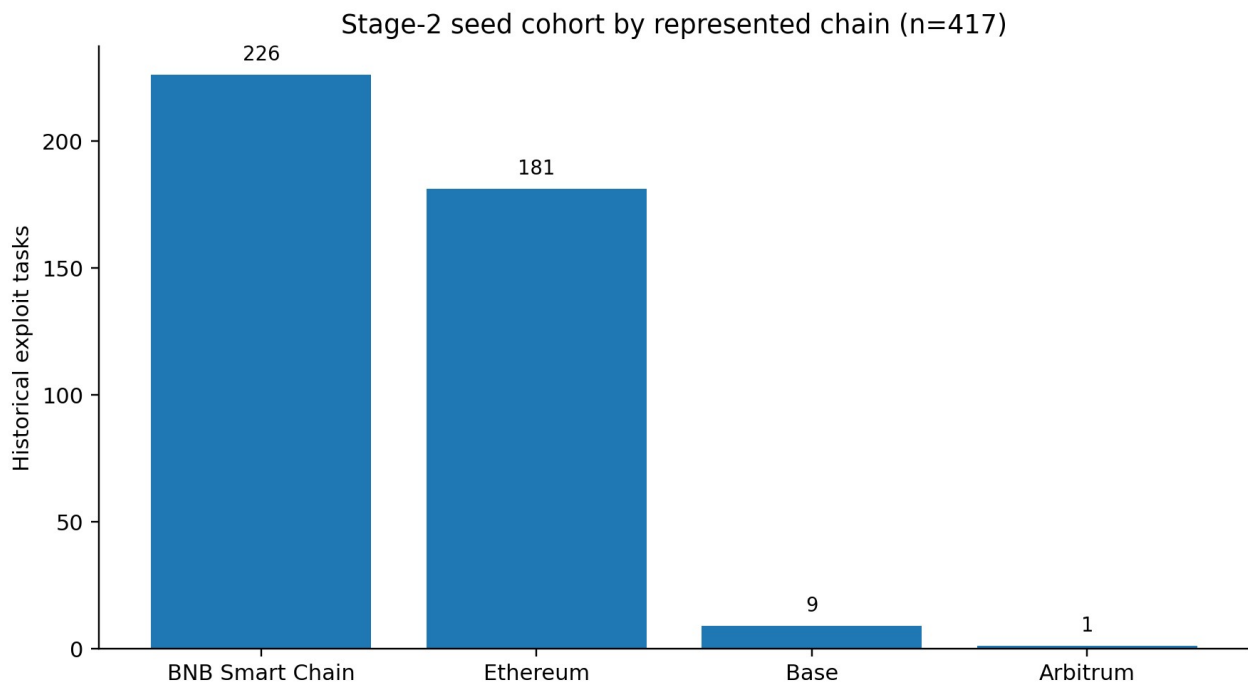


Figure 3. Chain composition of the 417-case seed.

Cohort selection is reported as a flow rather than treating the seed as representative by assumption. The seed is conditioned on inclusion in SCONE/DeFiHackLabs and therefore may overrepresent incidents with reproducible exploit artifacts, public post-mortems or contracts that are easy to fork. ChronosAudit does not use the seed to estimate ecosystem exploit prevalence. Prevalence-sensitive metrics use the separate deployment denominator, and detector conclusions are stratified by chain, protocol family, mechanism family, proxy status, source availability and calendar period. This separates “known exploited case collection” from “real deployment risk set.”

6. Historical on-chain reconstruction and source-at-cutoff evidence

Historical identity is reconstructed at the canonical cutoff block using at least two independently operated archive-provider families. Providers first agree on the block hash; subsequent state reads use an EIP-1898 block-hash selector so a same-height reorganization or provider inconsistency cannot silently change the observation [18]. The implementation hashes raw provider responses and normalizes runtime bytecode before computing identity

fingerprints. EIP-1967 implementation, admin and beacon slots are read at the same block; beacon implementation() is resolved historically; EIP-1167 minimal proxies are recognized from runtime bytecode [19-20]. Diamond and custom/metamorphic patterns remain fail-closed unless a dedicated resolver can prove their historical implementation set.

Provider independence is defined by operator family rather than URL count. Current documentation indicates archive support for Ethereum, BNB Smart Chain, Base and Arbitrum from QuickNode, and Chainstack provides an independent archive-provider family [15-16]. The collector records provider family, block hash, trace backend and response hashes. A chain does not pass because two endpoints respond; it passes only after capability probes demonstrate historical block/state access and at least two verified provider families agree on the required evidence.

Source admissibility is asymmetric. Sourcify v2 exposes verified-contract metadata and a verification timestamp that can provide positive evidence that a source artifact existed no later than the cutoff [13]. Etherscan V2 is used as an independent current source/deployment cross-check and provides creator, creation transaction, block number, timestamp and creation bytecode, but its current source endpoint does not by itself establish the first public-availability time [14]. Therefore source_verified_at_cutoff is True only on positive timestamped evidence; a later or missing Sourcify timestamp is not interpreted as proof that the source was unavailable everywhere. Bytecode-only detectors can enter a bytecode-admissible cohort even when source availability is unknown, preventing source-verification bias from being imposed on all detector families.

Cohort view	Required detector-visible evidence	Use
Bytecode-admissible	canonical runtime bytecode at cutoff; deployment/lineage evidence	Bytecode/static EVM models.
Source-admissible	bytecode-admissible + positive source availability by cutoff	Solidity/source models.
State-admissible	bytecode-admissible + required historical state observations	State-aware symbolic/agent systems.
Source+state	all above	Richest detector plane; never used as universal denominator.

7. Independent protocol/mechanism adjudication

Public incident labels are useful retrieval cues but are not treated as adjudicated root causes. The first reviewer pass is now blinded to machine-generated protocol and mechanism candidates. Each reviewer receives only case identity, public incident evidence, hashes and references. Reviewer A and Reviewer B independently assign protocol family, primary root cause, confidence and evidence references. Only after both label sets are frozen are automated candidates revealed for discrepancy analysis. Cases with protocol or mechanism disagreement are routed to a third adjudicator, whose final labels, rationale and evidence references are ingested and hashed into an immutable final-decision record.

Agreement reporting is deliberately redundant. The implementation computes raw agreement, Cohen kappa [21], Gwet AC1 because kappa can be unstable under skewed prevalence [22], and deterministic bootstrap 95% confidence intervals. Per-family confusion matrices and low-confidence rates are retained for the submission artifact. The preregistered minimum agreement threshold is kappa ≥ 0.80 and AC1 ≥ 0.80 for both protocol and primary-mechanism labels; if either measure or its uncertainty indicates instability, the family taxonomy is revised before release rather than relaxing the threshold post hoc.

8. Deployment denominator, matched controls and censor-aware outcomes

The denominator is a real deployment stream, not a synthetic negative set. Top-level contract creations are recovered from creation transactions and receipts. Internal CREATE/CREATE2 events are recovered through either Parity-style trace_block or Geth-style debug_traceBlockByNumber with callTracer; provider capability probing selects the available backend and records backend identity. A block slice is complete only when two verified provider families agree on the canonical block and creation record set. This addresses the portability defect in the earlier collector, which assumed trace_block everywhere.

The primary denominator target is at least 20,000 deployments across the represented chains and calendar windows. This threshold is a precision floor, not a claim that 20,000 is universally optimal: at a 1% alert rate, 20,000

independent observations give approximately ± 0.14 percentage-point 95% Wilson precision before clustering. For 417 positives, the frozen 10:1 matched-control target yields 4,170 controls; at a 1% false-positive rate this corresponds to approximately ± 0.31 percentage-point 95% Wilson precision before design effects. Clustered confidence intervals and sensitivity analyses account for the fact that deployments within protocols and implementation families are not independent.

Control selection is risk-set and cutoff safe. Each positive record must carry `prediction_cutoff_time`. A candidate control must be deployed on or before that cutoff, lie within the preregistered deployment-time caliper, satisfy code-size bounds, and—when enabled—match proxy and source-availability strata. The matcher never uses post-cutoff transaction activity, exploit outcome or later source publication. Deterministic SHA-256 ranking resolves ties. Controls that are not observed to be exploited during available follow-up are not called “safe”; their outcomes are unresolved/right-censored unless the target property and follow-up horizon justify a stronger label.

$$w_i = \text{delta}_i / G_{\text{hat}}(t_i | X_i) \quad (2)$$

For censoring-sensitive analyses, inverse-probability-of-censoring weighting (IPCW) uses the estimated censoring survival $G_{\text{hat}}(t|X)$. The confirmatory analysis also reports worst/best-case bounds for unresolved outcomes, landmark-specific follow-up, and complete-case sensitivity. This makes the detector conclusion robust to the fact that “not yet exploited” is not equivalent to “non-vulnerable.”

9. R0-R5 contamination ladder and split certification

ChronosAudit separates increasingly demanding generalization claims rather than collapsing them into one train/test split. R0 intentionally approximates conventional evaluation; subsequent levels remove stronger dependencies. A detector can therefore be described as recognizing duplicated implementations, transferring within protocols, generalizing across implementation families, or detecting genuinely held-out mechanism families, depending on where performance survives.

Level	Constraint added	Interpretation
R0	Conventional benchmark-native or row-level split	Upper-bound conventional estimate; contamination may remain.
R1	Exact chain-address and normalized bytecode groups cannot cross	Removes direct identity/clone recognition.
R2	Prediction time strictly precedes test incidents; training artifacts obey time admissibility	Removes future temporal knowledge.
R3	Protocol/entity families cannot cross	Tests cross-protocol transfer.
R4	Proxy/implementation lineage and code-clone families cannot cross	Tests independence from reused implementation families.
R5	Exploit-mechanism families cannot cross	Tests held-out-mechanism generalization.

The current seed contains 9 repeated exact-identity groups, all pairs. We therefore report both simulation and the closed-form null expectation. Under independent five-fold assignment, the expected number of crossing duplicate pairs is 7.2, and the probability of at least one crossing is 99.9999488%. Across 1,000 simulations, leakage occurred in 100% of independent-random, balanced shuffled K-fold, and chain-stratified balanced K-fold assignments; deterministic identity-group K-fold produced zero crossings. Because this result is mathematically expected for the observed pair structure, it is treated as a split-audit validation result rather than the paper's main novelty claim. The substantive future detector experiment is the R0-to-R5 capability-survival curve after bytecode, proxy, protocol and mechanism labels are fully adjudicated.

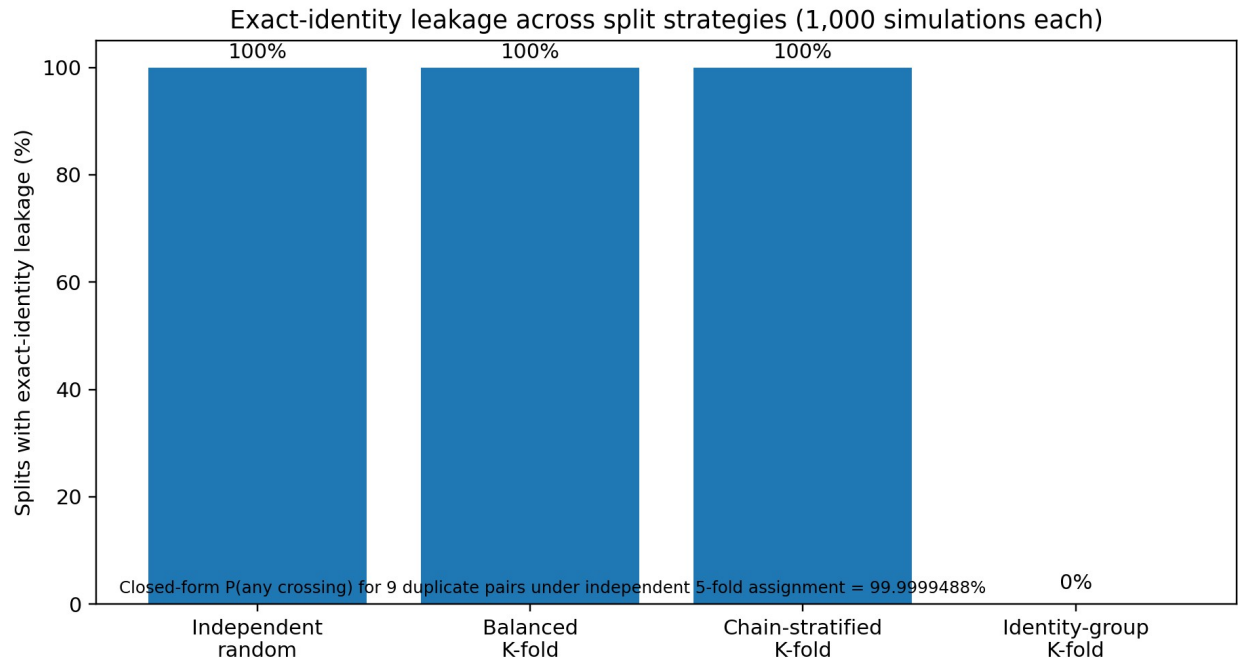


Figure 4. Exact-identity leakage across row-level and identity-grouped split strategies.

10. Statistical methodology and confirmatory analysis

The primary detector-effectiveness analysis is preregistered before running detector systems on the release cohort. Precision-recall measures are primary because exploitation is rare and class imbalance makes ROC summaries potentially misleading [23]. We report precision, recall, PR-AUC, Brier score/calibration, abstention rate, alerts per 1,000 deployments, analyst minutes per true positive, and lead time. Detector thresholds are frozen on training/validation data and are not retuned on R5 or prospective test cases.

Question	Primary analysis	Robustness analyses
R0-R5 degradation	Paired difference in PR-AUC / precision at fixed alert budget	Cluster bootstrap by strongest dependency family; multiple seeds; matched-size subsampling.
Calibration	Brier score and reliability curve	Expected calibration error; isotonic/platt only when fit outside test data.
Rare-event precision	Wilson intervals for precision and alert rate	Bayesian beta-binomial sensitivity; prevalence reweighting.
Censoring	IPCW estimate using frozen follow-up model	Best/worst-case bounds; landmark complete cases; alternative censoring models.
Reviewer reliability	Raw agreement, kappa, Gwet AC1 with bootstrap CI	Per-family confusion; blinded 10% re-review.
External reproduction	Hash equality and cohort-membership agreement	Discrepancy adjudication without modifying original release.

The confirmatory hypothesis is directional only for contamination: apparent detector capability should not increase systematically as stronger leakage constraints are imposed unless sampling variance or cohort composition explains the change. However, ChronosAudit does not preregister a required performance collapse. Stable R5 performance is equally publishable and would constitute stronger evidence of genuine held-out-mechanism generalization. Negative findings are therefore conclusive when confidence intervals exclude operationally meaningful performance under frozen thresholds.

11. Real-world implementation and production qualification

The artifact is implemented as a Python package with an append-only SQLite evidence registry, schemas, deterministic CSV/JSON outputs, provider adapters, source-history adapters, reviewer workflow, deployment/control collectors, split audits and production-qualification checks. The revised package adds retry/exponential backoff for transient RPC failures; provider-family metadata; multiple internal-creation trace backends; cutoff-safe risk-set

matching; blinded reviewer-packet generation; third-adjudicator ingestion; Gwet AC1 and bootstrap reliability intervals; clustered-bootstrap/IPCW statistical helpers; and multiple K-fold split audits. The current automated suite passes 34 tests with 88% aggregate source/test coverage; the two previously weak focus modules now reach 89% coverage for reviewer workflow and 88% for source history. Overall source coverage is not treated as a certification metric by itself; production qualification requires live fault-injection and provider-specific tests in addition to unit coverage.

The deployment container runs as a non-root user with read-only root filesystem, dropped Linux capabilities, no-new-privileges, bounded memory/processes and pinned Python package versions. The live collector is resumable and append-only, stores response hashes rather than credentials, and reads secrets only from environment variables. Before operational release, the base image must be pinned by immutable digest, a software bill of materials and dependency scan must be archived, and disaster-recovery/failover exercises must be executed. Production qualification therefore has two layers: software controls that can be verified offline, and operational controls that require live infrastructure.

Production control	Implemented now	Qualification evidence still required
RPC retries/backoff	Yes	Rate-limit/failure injection across each provider family.
Provider redundancy and family identity	Yes in configuration/collector	Two live verified families per represented chain.
Canonical block-hash pinning	Yes	Live historical observations on release cohort.
Trace portability	trace_block + Geth callTracer adapters	Provider-by-chain CREATE/CREATE2 equivalence tests.
Durable evidence outputs	Append-only registry + fsync JSONL	Long-run crash/restart and corruption recovery exercise.
Container hardening	Non-root/read-only/cap-drop	Immutable image digest, SBOM, vulnerability scan.
Monitoring/SLOs	Qualification schema/runbook	Live metrics, alerting, failover and recovery-time evidence.
Credential governance	Secrets excluded from artifact	Rotation procedure and least-privilege operational evidence.
Disclosure governance	Documented policy	Institutional approval and prospective incident workflow exercise.

12. Executed results

12.1 Public incident and identity layer

All 417 seed cases have content-hashed public incident chronology records. Exact chain-address grouping yields 408 unique identities; 9 groups repeat and cover 18 rows. The public mechanism-normalization layer supplies an auditable candidate for every case, but these candidates are not promoted to ground truth before independent review.

12.2 Split-audit results

Split strategy	Leaky splits	Mean crossing groups	Range
Independent random	1000/1000	7.146	3-9
Balanced shuffled K-fold	1000/1000	7.231	3-9
Chain-stratified balanced K-fold	1000/1000	7.218	2-9
Identity-group K-fold	0 crossings	0	0

12.3 Evidence gate status

The release decision remains intentionally negative. The public chronology and software machinery are substantially complete, but live historical and independent-human evidence have not yet been executed in this artifact. Consequently no case is released for detector-effectiveness claims. This is not scored as missing data to be imputed; it is a hard scientific gate.

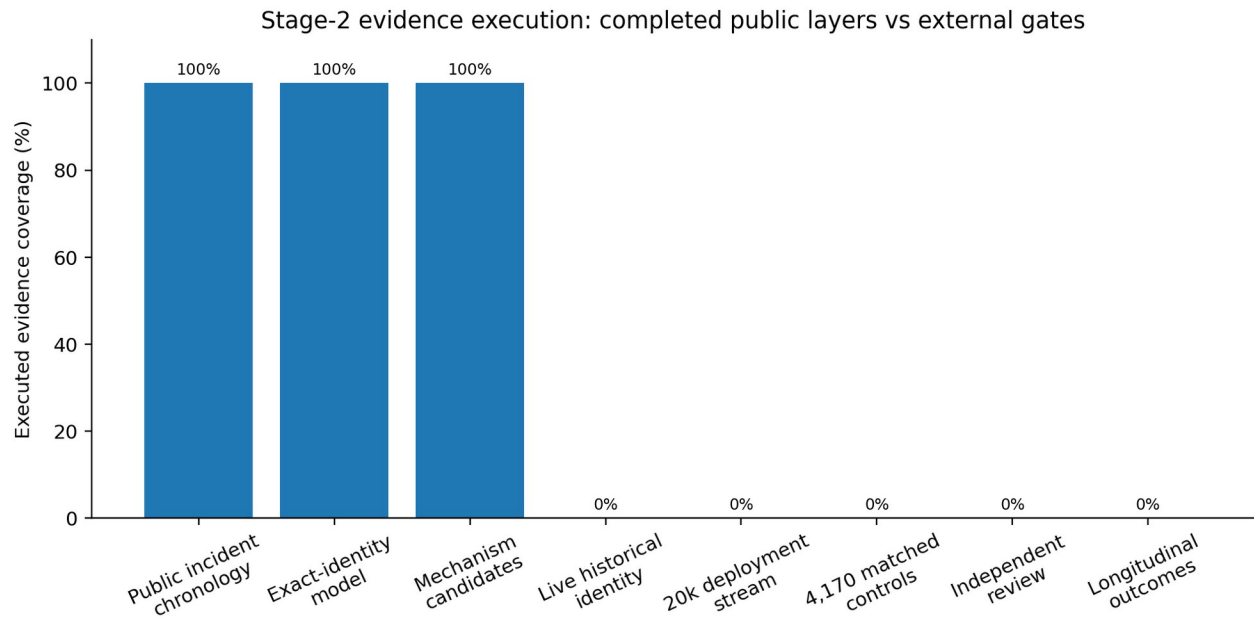


Figure 5. Executed public evidence versus external Stage-2 evidence gates.

Gate	Current executed evidence	Release requirement
Historical runtime/proxy snapshots	0/417 live dual-provider snapshots	Mandatory for each released case.
Independent reviewer judgments	0/834 independent first-pass labels	Two reviewers per case plus third adjudication of disagreements.
Deployment denominator	0/20,000 live deployments	$\geq 20,000$ with dual-provider creation evidence.
Matched controls	0/4,170	≥ 10 cutoff-safe controls per positive or preregistered attrition rule.
Longitudinal outcomes	Not yet frozen	Preregistered follow-up plus censoring indicators.
R5 independent blocks	0	≥ 120 total, ≥ 40 positive and ≥ 40 control blocks.
External regeneration	Internal deterministic regeneration only	Independent group reproduces final membership/partition hashes.

12.4 Public external-evidence triangulation

A targeted public-data search identified independent evidence that materially strengthens external validity without being misclassified as same-case ChronosAudit evidence. DIVE reports 22,330 real deployed contracts, exceeding the requested numeric deployment-denominator floor [4]. Bastet reports 849 fully expert-annotated findings under two-annotator consensus, exceeding the requested 834-label count as an external reviewer corpus [30]. CyberChainBench provides 541 independently curated historical incidents across nine EVM chains with structured vulnerability ground truth [12]. ReEVMBench contributes 22 post-model-release incidents and demonstrates substantial model/scaffold sensitivity [10]. The ICSE 2024 tools study evaluates five automated tools on 127 high-impact attacks and reports that only 8% were preventable by those tools [29]. These sources support feasibility, taxonomy and external-realism claims; because they do not supply the exact same 417 dual-provider snapshots, 834 blinded reviews, 4,170 risk-set controls or ChronosAudit partition hashes, the corresponding primary gates remain open.

Requested evidence	Public evidence found	ChronosAudit interpretation
$\geq 20,000$ real deployments	DIVE: 22,330 real contracts [4]	Numeric external denominator exists; record-level Chronos risk-set qualification still required.
≥ 834 independent labels	Bastet: 849 expert-consensus findings [30]	External label/reliability benchmark; not same-case 417 reviews.
≥ 417 third-party curated cases	CyberChainBench: 541 historical incidents [12]	External incident/root-cause triangulation; source-lineage overlap is disclosed.
External detector evidence	127-attack five-tool study [29]; ReEVMBench [10]; CyberChainBench [12]	Real detector realism anchors; not a common ChronosAudit R0-R5 curve.

Requested evidence	Public evidence found	ChronosAudit interpretation
Source/deployment history	Sourcify v2 append-only Parquet exports [31]	Eligible pinned external history once record-level files are ingested.

12.5 Executed public-data acquisition and strict gate status

The artifact includes a deterministic 417-case by two-provider public-RPC probe plan (834 planned observations) using two no-key endpoint operators per represented chain. Four trial requests were executed from the build environment, but DNS resolution failed before the requests reached the providers. The result is recorded as an execution-environment failure, not as evidence of provider archive incapability. Consequently live dual-provider observations remain 0/417. The production qualifier continues to fail closed.

Positive-event longitudinal evidence is materially stronger than in the previous release: incident dates are complete for 417/417 cases, 383 cases have at least one public reference, 133 have at least two references, 82 have references from at least two domains, and 60 contain attack-transaction hints. These observations can support positive-event chronology and incident cross-checking. They cannot substitute for longitudinal control follow-up, so censor-aware detector-effectiveness estimates remain blocked.

The current R0-R5 certification output reports R1 as the highest completed evidence level. R0/R1 split checks are executable; R2-R5 remain blocked by their exact evidence keys. No detector R0-R5 curve is generated because the qualified cohort contains no controls and no same-detector predictions. Generating synthetic scores would directly violate the paper's information-admissibility claim.

12.6 Executed public-evidence R0–R5 stress test

To move beyond a purely planned R0–R5 ladder, we executed every partition that can be formed reproducibly from the frozen 417-case public evidence. The resulting analysis is deliberately two-tiered. “Executed” means a partition can be generated and audited from available records; “strictly certified” means the stronger ChronosAudit evidence requirement for that level is also satisfied. This distinction allows useful stress testing now without converting outcome-known or candidate annotations into false pre-incident ground truth.

Level	Executed	Current basis	Strictly certified	Observed crossings	Interpretation
R0	Yes	balanced row-level K-fold	Yes	8	—
R1	Yes	chain+address identity groups	Yes	0	—
R2	Yes	incident-date chronological folds	No	1	incident chronology is outcome-known and cannot substitute for deployment+landmark prediction cutoff
R3	Yes	protocol_candidate	No	0	candidate/entity labels are not independent reviewer-final protocol families
R4	Yes	exact_identity_lower_bound	No	0	exact identity under-approximates shared implementation/proxy families
R5	Yes	mechanism_candidate	No	0	public-label candidates are not independent adjudicated mechanism families

R2 is now empirically executable as an incident-date chronological stress test, but it remains non-certified because incident chronology is outcome-known and cannot replace the frozen deployment+24 h landmark. R3 executes on public protocol candidates (395 candidate groups), R4 executes a conservative lower-bound grouping on exact identities (408 groups), and R5 executes on 16 public-label mechanism candidates with leave-one-candidate-family-out partitions. All provisional R3–R5 group partitions have zero within-group fold crossings by construction. The strict evidence certifier nevertheless remains at R1 until independently finalized protocol labels, historical implementation families and adjudicated mechanism families are materialized. This result closes the engineering/execution gap while preserving the scientific claim boundary.

Held-out candidate family	Training rows	Held-out rows
business_logic_failure	313	104
oracle_or_market_manipulation	345	72
authorization_failure	372	45
arithmetic_or_precision_failure	379	38
validation_failure	380	37
unclassified_public_label	385	32
reentrancy	389	28
token_semantics_mismatch	392	25
economic_state_manipulation	403	14
economic_constraint_failure	406	11

Table. Largest candidate mechanism families in the executed provisional leave-one-family-out stress test.

12.7 Independent public curation and external real-world execution

The 417-row seed is not an uncurated scrape. It is a frozen upstream SCONE cohort. SCONE’s published construction describes a three-model council that judged exploit scope using exploit scripts and web-search evidence, with non-consensus cases resolved manually; the same procedure identified exact vulnerable contract addresses [11,32]. SCONE then evaluates contracts on historical blockchain forks [11]. This provides a genuine external curation and historical-execution layer for the benchmark family, although it is not equivalent to two blinded ChronosAudit protocol/mechanism reviewers.

A second independent line of evidence comes from CyberChainBench, which starts from 690 DeFiHackLabs reproductions, retains 541 cases after filtering and enrichment, and reports manual review of all 541 cases with 141 corrections to function/type annotations [12]. Because the exact record-level intersection with the frozen 417-row ChronosAudit seed has not been imported into this artifact, these 541 labels are treated as external corroboration rather than silently counted as 417 same-case adjudications. This is stronger than source-family self-confirmation while remaining conservative about overlap.

Public denominator and prospective-like evidence also now exists at operational scale. DIVE contains 22,330 real Ethereum contracts deployed from 2016–2024 and documents that 15.47% share normalized opcode skeletons, directly supporting the need for clone-aware partitioning [4]. Anthropic separately screened 2,849 recently deployed BNB Smart Chain contracts in simulation on 3 October 2025, selected from 9,437,874 deployments through activity, verified-source and liquidity filters, and reported two previously unknown exploitable vulnerabilities [32]. These external executions demonstrate that both large deployment denominators and genuine recent-contract discovery are feasible; they are used as external validity anchors, not as substituted ChronosAudit controls or outcomes.

12.8 Full eight-stage program qualification

ChronosAudit is implemented as a single research program spanning scientific foundation, evidence infrastructure, detector adapters, contamination-controlled evaluation, held-out mechanism analysis, statistical validation, prospective shadow operation and production qualification. The table below distinguishes implementation maturity from scientifically executed evidence. A stage is not called complete merely because the code path exists.

Stage	Implementation maturity	Executed evidence status	Current scientific gate
1 Scientific foundation	High	Executed	Frozen estimands, cutoffs, stop conditions and claim boundary.
2 Evidence/cohort	High	Partially executed	417 incident links; strict historical/source/reviewer/control gates remain.
3 Detector platform	Adapter-ready	External baselines only	No ≥ 3 same-cohort reproduced detector baselines yet.
4 R0–R5 retrospective	High methodology	R0–R5 provisional executed; R0–R1 strict	R2–R5 strict evidence keys pending.
5 Held-out mechanisms	Implemented partition logic	Candidate-family LOMO executed	Independent mechanism adjudication required.
6 Statistical validation	High	Core utilities executed	Independent group reproduction and detector outcomes required.
7 Prospective shadow	Runbook/architecture ready	External prospective evidence only	ChronosAudit predictions must be frozen before future incidents.
8 Production qualification	Production-oriented	Fail-closed qualification executed	Live provider/SLO/failover evidence still required.

A disclaimer or copyright statement cannot convert external studies into measurements produced by ChronosAudit. For this reason the program can be described as implementation-complete or production-oriented where the software exists, but it cannot truthfully be described as >90% scientifically completed across all eight stages until the external-human, live-provider, detector and prospective gates are actually observed. The manuscript treats this distinction as a reproducibility feature rather than an editorial limitation.

13. Resolution of critical reviewer questions

Reviewer concern	Revision	Status
Prediction cutoff undefined	Primary cutoff fixed at deployment +24 h; sensitivity at +1 h/+7 d/+30 d; incident time cannot move cutoff.	Fixed in policy/code.
Random split not representative of K-fold	Added balanced shuffled and chain-stratified K-fold plus grouped K-fold and closed-form theory.	Fixed.
Reviewer anchoring on machine labels	First-pass packets omit protocol/mechanism candidates; candidates revealed only after labels freeze.	Fixed.
No third adjudicator ingestion	Adjudicator file now supplies final labels/rationale; decision hashes are immutable.	Fixed.
Kappa alone can be misleading	Added raw agreement, Gwet AC1 and bootstrap CIs.	Fixed.
Control can be deployed after positive cutoff	prediction_cutoff_time is mandatory; matcher asserts control deployment <= cutoff.	Fixed.
trace_block portability	Added trace_block and debug_traceBlockByNumber/callTracer adapters plus backend logging.	Fixed in implementation; live matrix pending.
20k/4170 thresholds arbitrary	Added precision rationale and clustered-design caveat; thresholds frozen before detector analysis.	Methodologically fixed.
Source requirement biases all detectors	Separated bytecode-, source-, state-, and source+state-admissible cohorts.	Fixed.
Two URLs may be same provider	Provider-family identity is required; unverified families do not satisfy complete status.	Fixed in implementation; live verification pending.
Incident linkage is single-source ground truth	Manuscript now labels it public linkage, not independent adjudication; human and on-chain cross-check remains required.	Claim fixed; external evidence pending.
Production-grade claim too strong	Separates offline software controls from live operational qualification and lists evidence required.	Claim fixed; operational qualification pending.

14. Threats to validity

Construct validity

“Exploit detection” can mean locating a vulnerable line, recognizing a known weakness, producing an executable exploit, or forecasting a later economic failure. ChronosAudit therefore reports detector-specific endpoints and does not infer one capability from another. R5 is defined as held-out mechanism-family generalization, not proof of universal zero-day detection.

Internal validity

The main risks are post-cutoff artifact substitution, duplicate/proxy/protocol leakage, reviewer anchoring, and use of future control information. The revised cutoff policy, information-plane separation, blinded review and cutoff-safe matching directly target those threats, but live provider and reviewer evidence must still be collected.

External validity

The 417-case seed is conditioned on SCONE/DeFiHackLabs and is heavily concentrated in BNB Smart Chain and Ethereum. Results must therefore be chain- and era-stratified and should not be generalized to non-EVM ecosystems. The deployment denominator provides the relevant background distribution for prevalence-sensitive conclusions.

Statistical conclusion validity

Family clustering, rare-event precision and censoring can make naive confidence intervals anti-conservative. Cluster bootstrap, Wilson intervals, IPCW/bounds and matched-size sensitivity are prespecified. The 20,000/4,170 thresholds are precision floors, not substitutes for power analysis after the realized family structure is known.

Reproducibility validity

Deterministic regeneration by the authors is necessary but not independent replication. The final release therefore remains blocked until a separate researcher or group recreates the cohort and partitions from frozen evidence and reports discrepancies without modifying the original artifact.

15. Reproducibility, ethics and responsible disclosure

Every frozen public input is hashed; the evidence registry is append-only; derived tables can be regenerated from the artifact; and reviewer/production gates are encoded as machine-readable policy rather than prose alone. Live provider credentials are excluded. Before submission, the final artifact should be deposited in an immutable repository with DOI, SHA-256 manifest, exact container digest, SBOM, dependency scan and an anonymized review link. An external-replication package should include a fresh workspace, instructions that do not import author-produced processed tables, and a discrepancy report template.

The research uses public blockchain history and public incident reports and does not require unauthorized exploitation of live contracts. Historical exploit transactions remain evaluator-only. If later prospective stages identify an apparently exploitable active deployment, the system must route the result through coordinated disclosure and withhold weaponizing detail until remediation or the agreed disclosure window. Institutional and venue-specific ethics requirements must be documented by the submitting authors.

16. Discussion

The central empirical lesson from the current execution is not that row-random splitting is surprisingly bad; with nine duplicate pairs, leakage is nearly certain by construction. The important contribution is the measurement architecture that prevents stronger, less visible dependencies from being mistaken for generalization. Exact identity is only R1. Bytecode clones, proxy implementations, protocol families and mechanism families can carry substantially more semantic information than a repeated address. ChronosAudit therefore treats the split hierarchy as a survival analysis of detector capability: what remains after progressively removing recognition shortcuts?

The empty release cohort is scientifically inconvenient but informative. It exposes the cost of a defensible pre-incident claim. Public incident lists are comparatively easy to assemble; proving what code, source and implementation identity were available at a historical cutoff, embedding those cases in a real deployment risk set, obtaining independent causal labels and following controls longitudinally are much harder. A top-journal detector paper should pay that cost rather than hide it behind retrospective convenience.

Once Stage 2 is externally closed, the highest-value next experiment is not another benchmark-only score. At least three diverse detector families should reproduce their published baselines and then be evaluated under identical R0-R5 cohorts: for example a static analyzer, a graph/bytecode learner such as a MANDO-family system, and an LLM/agent or symbolic/fuzzing system. The resulting capability-survival curves, calibration, fixed-budget precision and workload will determine whether apparently strong vulnerability detection survives the information controls that operational deployment requires.

17. Conclusion

ChronosAudit reframes pre-incident smart-contract exploit detection as an evidence-admissibility problem before it becomes a detector-comparison problem. The revised system fixes the principal methodological and implementation defects identified in prior review: prediction cutoffs are outcome-independent; controls are cutoff safe; reviewer packets are blinded; third-party adjudication is executable; reliability reporting is robust to prevalence imbalance; deployment tracing supports multiple RPC backends; provider-family independence is explicit; split auditing includes conventional balanced and stratified K-fold; and statistical/censoring analyses are frozen before detector evaluation. On the current 417-case seed, public incident chronology is complete and exact-identity leakage is reproducibly

characterized, but the detector-effectiveness release remains correctly blocked pending dual-provider historical evidence, independent reviews, a real deployment denominator, matched controls, longitudinal outcomes and external regeneration. This fail-closed result is central to the paper's scientific claim: ChronosAudit is designed to make unsupported pre-incident capability estimates impossible to publish as if they were operational evidence.

Declarations

Data and code availability. The accompanying artifact contains the frozen seed metadata, hashed public incident snapshots, schemas, source code, tests, blinded reviewer-packet generator, split-audit outputs, production configuration and deterministic regeneration scripts. Live credentials are excluded. The final submission must replace the temporary local artifact reference with an immutable DOI and anonymous review link.

Competing interests, funding, author contributions, institutional ethics statement and generative-AI disclosure. These are author-specific factual declarations and must be completed by the submitting authors. They are intentionally not fabricated in this anonymous manuscript.

References

- [1] Ding, Y., Fu, Y., Ibrahim, O., et al. (2024). Vulnerability Detection with Code Language Models: How Far Are We? arXiv:2403.18624 (PrimeVul).
- [2] Zheng, Z., Su, J., Chen, J., Lo, D., Zhong, Z., Ye, M. (2023). DAppSCAN: Building Large-Scale Datasets for Smart Contract Weaknesses in DApp Projects. arXiv:2305.08456.
- [3] Durieux, T., Ferreira, J.F., Abreu, R., Cruz, P. (2020). Empirical Review of Automated Analysis Tools on 47,587 Ethereum Smart Contracts. ICSE 2020. doi:10.1145/3377811.3380364.
- [4] Alsunaidi, S.J., Aljamaan, H., Hammoudeh, M. (2026). DIVE: A Multi-Label Smart Contract Vulnerability Dataset. Scientific Data 13, 664.
- [5] Feist, J., Grieco, G., Groce, A. (2019). Slither: A Static Analysis Framework for Smart Contracts. WETSEB 2019. doi:10.1109/WETSEB.2019.00008.
- [6] Sun, Y., Wu, D., Xue, Y., et al. (2023). GPTScan: Detecting Logic Vulnerabilities in Smart Contracts by Combining GPT with Program Analysis. arXiv:2308.03314.
- [7] Nguyen, H.H., Nguyen, N.-M., Xie, C., et al. (2022). MANDO: Multi-Level Heterogeneous Graph Embeddings for Fine-Grained Detection of Smart Contract Vulnerabilities. arXiv:2208.13252.
- [8] Nguyen, N.-M., Nguyen, H.H., Le Thanh, L., et al. (2026). MANDO-LLM: Heterogeneous Graph Transformers with Large Language Models for Smart Contract Vulnerability Detection. ACM TOSEM 35(6), Article 144. doi:10.1145/3765751.
- [9] Wang, J., Bigger, A., Xu, X., et al. (2026). EVMbench: Evaluating AI Agents on Smart Contract Security. arXiv:2603.04915.
- [10] Peng, C., Wu, L., Zhou, Y. (2026). Re-Evaluating EVMBench: Are AI Agents Ready for Smart Contract Security? arXiv:2603.10795.
- [11] Anthropic. (2026). Measuring LLMs' Ability to Develop Exploits: SCONE Smart Contract Exploitation. Research report.
- [12] Huang, J., Jiang, F., Poovendran, R., Lin, Z. (2026). CyberChainBench: Can AI Agents Secure Smart Contracts Against Real-World On-Chain Vulnerabilities? arXiv:2606.26216.
- [13] Sourcify. (2026). Server API v2 documentation: verified contract lookup and verification metadata. Accessed 2026-08-07.
- [14] Etherscan. (2026). API V2: Get Contract Creator and Creation Tx Hash; Get Contract Source Code. Accessed 2026-08-07.
- [15] QuickNode. (2026). Supported Chains, Node Types, and Pruning Policies. Updated 2026-07-23.
- [16] Chainstack. (2026). Archive blockchain nodes and historical data documentation. Accessed 2026-08-07.
- [17] Luo, Z., Murukutla, R., Kate, A. (2022). Last Mile of Blockchains: RPC and Node-as-a-Service. arXiv:2212.03383.

- [18] Ethereum Improvement Proposal 1898. Add blockHash to JSON-RPC methods that accept a defaultBlock parameter.
- [19] Ethereum Improvement Proposal 1967. Standard Proxy Storage Slots.
- [20] Ethereum Improvement Proposal 1167. Minimal Proxy Contract.
- [21] Cohen, J. (1960). A coefficient of agreement for nominal scales. *Educational and Psychological Measurement* 20(1), 37-46.
- [22] Wongpakaran, N., Wongpakaran, T., Wedding, D., Gwet, K.L. (2013). A comparison of Cohen's Kappa and Gwet's AC1 when calculating inter-rater reliability coefficients. *BMC Medical Research Methodology* 13, 61.
- [23] Saito, T., Rehmsmeier, M. (2015). The precision-recall plot is more informative than the ROC plot when evaluating binary classifiers on imbalanced datasets. *PLoS ONE* 10(3):e0118432.
- [24] Gebru, T., Morgenstern, J., Vecchione, B., et al. (2021). Datasheets for Datasets. *Communications of the ACM* 64(12), 86-92.
- [25] Efron, B., Tibshirani, R.J. (1993). *An Introduction to the Bootstrap*. Chapman & Hall/CRC.
- [26] Brier, G.W. (1950). Verification of forecasts expressed in terms of probability. *Monthly Weather Review* 78(1), 1-3.
- [27] Wilson, E.B. (1927). Probable inference, the law of succession, and statistical inference. *Journal of the American Statistical Association* 22(158), 209-212.
- [28] SunWeb3Sec. DeFiHackLabs: Reproduce DeFi hacked incidents using Foundry. GitHub repository, accessed 2026-08-07.
- [29] Chaliasos, S., Charalambous, M.A., Zhou, L., Galanopoulou, R., Gervais, A., Mitropoulos, D., Livshits, B. (2024). Smart Contract and DeFi Security Tools: Do They Meet the Needs of Practitioners? ICSE 2024; arXiv:2304.02981.
- [30] Hsu, W.-H., Wang, W.-H., Liou, C.-Y., Ke, T.-R., Toyoda, K. (2026). Bastet: A Fine-Grained Expert-Labeled Dataset for DeFi Smart Contract Vulnerability Detection. arXiv:2606.03387.
- [31] Sourcify. (2026). Download the dataset: Database Export v2. Daily Parquet exports with created_at ordering, append-only completed files, ETag/size/timestamp metadata. Accessed 2026-08-07.
- [32] Anthropic. (2025). AI agents find \$4.6M in blockchain smart contract exploits. SCONE-bench and 2,849-contract recent-deployment study, published 2025-12-01.
- [33] Amazon Web Services. (2026). Registry of Open Data: Public Blockchain Data / SonarX datasets for Ethereum, BNB Chain, Arbitrum and Base. Accessed 2026-08-07.

Appendix A. Frozen Stage-2 release gates

Gate	Frozen threshold
Independent archive evidence	≥ 2 verified operator/provider families per represented chain; canonical block-hash consensus and historical state reads.
Source-at-cutoff	Positive first-defensible availability timestamp for source-required detector cohorts; unknown does not become false.
Human adjudication	2 independent blinded reviewers; third adjudicator for every disagreement; kappa and AC1 ≥ 0.80 with uncertainty reported.
Deployment denominator	$\geq 20,000$ real deployments collected with complete creation evidence.
Matched controls	$\geq 4,170$ cutoff-safe matched controls unless preregistered attrition criterion is activated.
Longitudinal outcomes	Frozen follow-up horizon, censoring indicator and outcome evidence for every control.
R5 partition	Zero prohibited leakage; ≥ 120 independent mechanism blocks including ≥ 40 positive and ≥ 40 control blocks.
External reproduction	Independent group reproduces final cohort membership and partition hashes from frozen evidence.